

INDEPENDENT REVIEW

Expert review of the Pega 26.1.1 Kafka and Search Runbook

Version 2.0 reviewed and corrected as 2.1; data review of 2.1 issued as 2.2

2 October 2026 | Customer Confidential

1 Summary

Version 2.0 of the runbook was reviewed against fourteen dimensions, from vendor alignment to sizing and observability. The review found 24 issues. Three were critical: the SRS Helm values in version 2.0 would not have installed, Pega would have called SRS on the wrong port, and the SRS chart's own network policy would have blocked SRS from reaching OpenSearch and Okta. All three were found by rendering the values files with `helm template` against charts 4.13.0, which reading the README alone did not reveal.

The other findings were gaps rather than errors: availability zone design, Confluent's enforced connection and request limits, the installer's possible need for Kafka, Okta key rotation and rate limits, OpenSearch sizing formulas, performance testing, sizing and observability. Version 2.1 corrects every finding. Seven items remain open because only the customer, Pega Support or a DEV test can close them (Section 6).

A second review of version 2.1 looked at the data itself: what Pega puts on Kafka and into OpenSearch, how sensitive it is, and how it is protected, kept, erased and recovered. It found eleven gaps (F-25 to F-35). The most serious were three choices that are fixed when a resource is created: the Confluent encryption key mode, whose Enterprise variant needs a Key Vault reachable from all networks; AKS encryption at host, without which logs and heap dumps sit on unencrypted ephemeral disks; and the data class of the shared PERF and PREPROD services. Version 2.2 adds Section 9 to the runbook to close them.

Table 1. Findings by severity

Severity	Meaning	Count
Critical	The deployment would fail or be insecure as written	3
High	A likely production incident, failed test or wrong size	14
Medium	A gap that would cost time or cause a defect in testing	15
Low	A small inaccuracy or inconvenience	3

2 Method

The review was done the way an implementation lead checks a runbook before a first build: by running what can be run, and checking every other statement against the vendor's current page.

- Rendered every Pega and backingservices values file with `helm template` against charts 4.13.0 and read the generated Deployments, Services, Jobs, HPAs, ConfigMaps and NetworkPolicies.
- Read the chart templates where the README is silent, for example the tier template for `topologySpreadConstraints` and the SRS network policy template [R61, R62].
- Rechecked Confluent, OpenSearch, Okta, Azure and Pega pages for limits, conditions and defaults, and added fifteen references (R49 to R63 in the runbook). The data review added sixteen more (R64 to R79) on queue processor payloads, SRS indexing scope, Pega encryption, Confluent keys and TLS, OpenSearch TLS and audit logs, and AKS disk encryption.
- Recalculated the sizing calculator in LibreOffice Calc and compared every output with the Python functions that produce the runbook's worked example.
- Ran the runbook's QA script (cross-references, decision IDs, wording) and an ID check over the built document: every scenario, test, step and command ID used is defined.
- Reviewed the rebuilt PDF page by page for the changed sections.

3 Evaluation dimensions

Table 2. Evaluation dimensions

ID	Dimension	What was checked	Evidence used
D1	Alignment with Pega	Every Pega requirement for external Kafka and SRS is met; nothing contradicts Pega '25 and '26 pages or the chart README	Pega pages R3 to R22, R49 to R51; chart README R23, R24, R63
D2	Alignment with Confluent Cloud	Cluster type, limits, SLA conditions, networking, ACLs and quotas match Confluent's published rules	R31 to R36, R56, R57
D3	Alignment with OpenSearch and SRS	Versions, cluster settings, roles, sizing and zone layout follow OpenSearch and Pega SRS guidance	R14, R24, R37 to R41, R54, R55, R58
D4	Helm correctness	Every values file renders against charts 4.13.0 and produces the intended objects	helm template of all values files; rendered manifests
D5	Security and isolation	Credentials, tokens, network paths and data are separated per environment, with tests	Isolation tests IT-01 to IT-10; network policy render
D6	Architecture and cloud design	Availability zones, failure domains, private networking, scaling and blast radius	R32, R47, R59; Azure design practice
D7	Failure handling and remediation	Known issues, failure scenarios and troubleshooting cover what goes wrong in practice	Failure catalogue; known-issue tables
D8	Testing methodology	Test stages, entry and exit criteria, evidence and rehearsals	Section 15
D9	Performance testing	Need, workload model, test types, harness, measurement points, pitfalls	Section 16
D10	Sizing	Method and formulas per layer, with a working calculator	R31, R49, R54, R55; calculator recalculated in LibreOffice
D11	Monitoring, logging and observability	Telemetry from every layer, alerting, dashboards, Pega Diagnostic Center, correlation	R51, R52, R56 to R58, R60
D12	Environment sequencing and configuration	Order of build, what is reused, per-environment checklist, refresh and retirement	Sections 13 and 20
D13	Evidence and traceability	Every statement sourced; conflicts logged; questions traced to sections	Reference register; QA script
D14	Readability for the customer	Plain English, consistent IDs, no unresolved cross-references	QA script; ID check; page review
D15	Data flows and data protection	What Pega puts on Kafka and into OpenSearch, its class, encryption in transit and at rest, operational copies, residency, retention, erasure and failure handling	R7, R33, R58, R64 to R79; Section 9

4 Findings and corrections

F-01 to F-24 were found in version 2.0 and corrected in 2.1; F-25 to F-35 were found in 2.1 and corrected in 2.2. The evidence column names the version where the problem was found. Section numbers in the correction column are those of version 2.2, in which Sections 9 to 20 of version 2.1 became Sections 10 to 21.

Table 3. Findings register

ID	Dim.	Severity	Finding	Evidence	Correction
F-01	D4	Critical	The backingservices values set <code>srsStorage.tls.enabled: true</code> together with basic authentication. In the SRS chart <code>tls</code> means certificate authentication, and the chart refuses to render: "Only one authentication can be enabled".	helm template of the v2.0 SIT and PROD files failed with that message [R24]	<code>tls.enabled: false</code> ; encryption from <code>protocol: https</code> . Sections 7.7 and 10.3, Appendix B
F-02	D4	Critical	<code>pegasearch.externalURL</code> had no port. With SRS TLS enabled the SRS container listens on 8443 only, and its Service exposes 8080, 80 and 8443. An HTTPS URL without a port goes to 443, so search would fail at the first start.	Rendered SRS Deployment and Service: containerPort 8443, probes on <code>https://localhost:8443/health</code> [R62]	URL ends in <code>:8443</code> in all six environments; flow table, S-5 and Appendix B updated
F-03	D4, D5	Critical	The chart network policy (<code>srsStorage.networkPolicy.enabled: true</code>) allows SRS egress only to an in-cluster <code>elasticsearch-master</code> on 9200 and DNS, and ingress from <code>0.0.0.0/0</code> . It blocks the external OpenSearch service and the Okta key set and lets any pod call SRS.	Rendered NetworkPolicy from the v2.0 values [R62]	Chart policy off; replacement default-deny and allow policies per environment (Section 7.7, Appendix B, NW-5, SR-2)
F-04	D4	Medium	Section 9.3 listed <code>srsStorage.tls.enabled</code> and <code>networkPolicy.enabled</code> as <code>true</code> , contradicting the corrected design once F-01 and F-03 are fixed.	Section 9.3 table in v2.0	Table corrected; new SRS chart behaviours table
F-05	D3	High	One SRS replica in DEV, SIT and UAT. The SRS chart README states a minimum of 2 replicas and 3 as best practice, while Pega's sizing table shows 1 for test landscapes.	R14 against R24	2 replicas in DEV, SIT and UAT; conflict logged as RC-10
F-06	D3	Medium	SRS resources were left at chart defaults (1.3 CPU limit, 4Gi) without noting that Pega's sizing table gives 2 CPU per SRS pod.	R14 against R24	Explicit resources: request 1 CPU, limit 2 CPU, 4Gi; RC-11
F-07	D6	High	No availability zone design. Pega tiers had no zone spread, SRS no anti-affinity, node pools no zone headroom, and the Confluent and OpenSearch zone conditions were not stated.	v2.0 Sections 4 and 9; R31, R59	New Section 4.6 with figure; <code>topologySpreadConstraints</code> per tier (rendered), SRS anti-affinity, 1.5 times node headroom; RC-12
F-08	D2	High	Confluent connection, connection-attempt and request limits per eCKU, now enforced on Enterprise clusters, were missing. Rolling restarts of shared environments can be throttled.	R31, R56	Limits table extended; enforcement callout; FS-31; throttling alert; RK-13
F-09	D2	Medium	Partition creation and deletion pacing (500 per five minutes on Enterprise) was missing. It lengthens first starts and refreshes in shared groups.	R31	Callout in Section 6.3; FS-32; one refresh per group at a time
F-10	D2	High	The 99.99 % SLA conditions were missing: at least 2 eCKU on Enterprise; Dedicated only if created multi-zone, which cannot be changed later.	R31	Section 6.3 callout; minimum 2 units for NP2 and PROD; calculator applies the minimum
F-11	D1, D2	Medium	The partition budget did not use Pega's default of 6 partitions per topic or the rule that queue processor threads beyond the partition count do no work. A clone can carry a changed partition DSS from 8.8.	R49, R50	Formulas in Section 6.7; CD-15; known issues; performance pitfalls
F-12	D1	High	The upgrade path did not ask whether the installer needs Kafka. From '25 Pega command-line tooling needs Kafka, but chart 4.13.0 passes no stream settings to the installer job.	R8; rendered run U has no <code>STREAM_*</code> values	GQ-08; callout in Section 6.9; RK-15; known issue

ID	Dim.	Severity	Finding	Evidence	Correction
F-13	D5, D7	High	Okta signing key rotation (about four times a year) and org-wide rate limits shared by all environments were not covered.	R52, R53	Section 7.6 subsection; FS-33, FS-35; rate-limit alert; RK-14
F-14	D5	Medium	Client key rotation assumed Okta would pick the right key; Pega does not state whether its client assertion carries a <code>kid</code> header.	R45; Pega pages silent	FS-34 with two registered keys before any production rotation
F-15	D3, D10	Medium	OpenSearch sizing gave starting sizes only, with no storage, shard or node formulas.	R54, R55	Formulas table in Section 7.4; zone awareness; Appendix H; RC-13
F-16	D1, D11	Medium	No JVM guidance: no GC logging, no metaspace cap, no time zone setting for a database cloned from a non-UTC 8.8 system.	R23, R63	Section 10.2 subsection; <code>javaOpts</code> in values (rendered); known issues
F-17	D1, D11	Medium	A clone carries production's Pega Diagnostic Center setting, so non-production alerts would reach the production PDC system.	R51	CD-16; Section 19.3
F-18	D9	High	Performance testing was four rows in a table: no reason why it is needed, workload model, test types, harness, measurement points, entry and exit criteria or pitfalls.	v2.0 Section 14.5	New Section 16 with harness figure and six measurement points; RK-16
F-19	D10	High	No sizing method across layers and no calculator.	v2.0	Sections 16.7 to 16.9; Excel calculator with live formulas, checked by recalculation
F-20	D11	High	Monitoring was one table and a small figure. No logging design, no Confluent Metrics API or audit log specifics, no OpenSearch slow logs, no PDC, dashboards, synthetic checks or correlation method.	v2.0 Section 17.1	New Section 19 with telemetry pipeline figure; alert table extended from 12 to 19 signals
F-21	D12	Medium	No explicit order for building the six environments and no per-environment configuration checklist.	v2.0 Section 12	Section 13.10 with build waves figure, exit check per wave and a 13-item checklist
F-22	D7	Low	Command S-5 called the SRS HTTPS endpoint without the private CA, so it would fail on TLS before testing the token.	Appendix C in v2.0	--cacert added; health call added
F-23	D13	Low	The telemetry figure showed GC logs on stdout, while Pega's recommended setting writes them to a file.	R63	Figure redrawn
F-24	D7	Medium	Known issues did not cover the defects above, or platform issues such as uneven zone spread, out-of-memory kills and time zone drift.	v2.0 Section 15	14 new known-issue rows, including a new Platform table; 5 new failure scenarios
F-25	D15	High	No statement of what Pega actually sends to Kafka and OpenSearch. Queue messages carry the producer's operator, access group and application, and either a record key or the whole page; SRS indexes only listed properties unless a DSS widens it.	v2.1; R64, R65, R67, R68	Section 9.1 with data flow figure and a 14-item data inventory
F-26	D15	High	No data class per environment group. NP2 is shared by PERF and PREPROD; an unmasked PREPROD would put production personal data on a shared service reachable by its administrators.	v2.1 Sections 5 and 10.5	Section 9.2; OD-15 (mask both); RK-18
F-27	D15	Medium	No controls to limit the data copied: the queue snapshot option, the indexed property list, <code>indexer/srs/indexAllFieldsForFTS</code> and <code>PropertyEncrypt</code> policies.	R64, R67, R68, R71	Section 9.3; DT-01, DT-03, DT-04; GQ-09
F-28	D15, D6	High	Confluent self-managed keys not considered. The mode is fixed at cluster creation, and on Enterprise the Key Vault must allow public access from all networks, which conflicts with step SI-1.	R73, R74	Section 9.5; OD-14; DA-3; SI-1 note; known issue

ID	Dim.	Severity	Finding	Evidence	Correction
F-29	D15, D6	High	AKS node storage not covered. Ephemeral OS disks, temp disks and caches are encrypted only with encryption at host, set at node pool creation, and the v2.1 JVM settings write heap dumps there.	R78, R79	Section 9.5; OD-18; DA-2; DP-6; Section 4.6 row
F-30	D15	High	No rules for operational copies: heap dumps hold decrypted values and secrets, broken items hold the payload, slow logs hold search terms, and console consumers copy PROD messages.	R58, R64	Section 9.6 rules table; DT-09, DT-10; RK-19
F-31	D15	Medium	Retention and erasure missing. Confluent keeps messages 7 days by default and cannot delete a single record; Pega's removal of index documents on purge is not documented; snapshots keep erased data.	R33; Pega pages silent	Section 9.7; OD-16, OD-17; GQ-11; DT-05, DT-06
F-32	D7, D15	Medium	Data behaviour under failure not described: database fallback when Kafka is down, broken queue, repeat delivery, 100-item bulk failure, fields skipped by <code>failOnUnrecognisedValue</code> , and loss when lag exceeds retention.	R33, R64, R66, R69, R70	Section 9.8 with figure and DF-01 to DF-11; three new alerts; RK-21
F-33	D3, D15	Medium	Provider criteria lacked encryption at rest, HTTPS-only REST, node-to-node TLS and audit logging. OpenSearch allows plain HTTP on the REST layer.	R76, R77	Three rows added to the provider worksheet (Section 7.3); AS-12
F-34	D8, D15	Medium	No data tests and no data evidence in the acceptance criteria.	v2.1 Section 14	DT-01 to DT-12 with commands DP-1 to DP-6; AC-7; evidence item E-11; DA steps
F-35	D2	Low	TLS versions on Confluent not stated: TLS 1.3 preferred with TLS 1.2 fallback, and Dedicated clusters created before 30 April 2026 need TLS 1.3 enabled.	R75	Section 9.4

4.1 Confirmed as correct

These design points were checked and needed no change.

Table 4. Design points confirmed

Area	Design point	Source
Kafka ACLs	TOPIC and GROUP ALL PREFIXED on the environment prefix; TRANSACTIONAL_ID *; CLUSTER IDEMPOTENT_WRITE	R11
Kafka settings	Replication factor 3; topic <code>max.message.bytes</code> 5,000,000; broker settings that are not editable on Confluent Cloud logged as RC-03	R11, R33, R34
No stream or index migration from 8.8	Embedded Kafka and Elasticsearch data cannot be moved; indexes are rebuilt through SRS	R13, R15
Run sequence	<code>upgrade</code> run, then first start with the batch tier at zero, then deploy; <code>upgrade-deploy</code> avoided	R23
Hazelcast	Disabled; removal question raised for an offline-upgraded clone (GQ-03)	R5, R6
customerDeploymentId	Set explicitly per environment and matched to the Okta <code>guid</code> claim	R23
Okta	Custom authorization server needed for the custom scope and claim	R42 to R44
Cluster settings for SRS	Index auto-creation off; <code>destructive_requires_name</code> false	R14
Private Link DNS	Wildcard and zonal records; checks K-1 to K-3	R32
Secrets	External secrets only; keys named as the chart requires	R23, R48

5 Scorecard

Scores are the reviewer's judgement on a five-point scale: 1 missing or wrong; 2 present with errors that would cause failures; 3 correct but with material gaps; 4 complete for the current stage, with inputs still to be measured; 5 complete and verified. A score of 4 after correction means the method is in place but depends on measurements or decisions that only the programme can supply.

Table 5. Scorecard by version

ID	Dimension	2.0	2.1	2.2	What limits the score
D1	Alignment with Pega	4	5	5	None, pending Pega Support answers
D2	Alignment with Confluent Cloud	3	5	5	None
D3	Alignment with OpenSearch and SRS	3	5	5	None, pending the provider choice
D4	Helm correctness	2	5	5	None; all files render
D5	Security and isolation	4	5	5	None
D6	Architecture and cloud design	3	4	4	NP1 may run in fewer zones to save cost; provider zone features not yet known
D7	Failure handling and remediation	4	4	5	None
D8	Testing methodology	4	4	4	Results of DEV-only tests still to be recorded
D9	Performance testing	2	4	4	Workload model needs 8.8 production data
D10	Sizing	2	4	4	Inputs are illustrative until measured
D11	Monitoring, logging and observability	2	4	4	Provider log export and the customer's SIEM not yet confirmed
D12	Environment sequencing and configuration	3	4	4	Wave dates set by the programme
D13	Evidence and traceability	4	5	5	None
D14	Readability for the customer	4	4	4	Long technical tables in places
D15	Data flows and data protection	1	2	4	Pega Support answers GQ-09 to GQ-11 and the customer's key and classification decisions

6 Items that remain open

Table 6. Open items after version 2.2

Item	Owner	Needed by	Why the document cannot close it
Pega Support answers GQ-01 to GQ-11	Pega LSA	M2	Only Pega Support can settle them; the plan follows the conservative answer until then
Data decisions OD-14 to OD-18: Confluent keys, data class of PERF and PREPROD, topic retention, broken item retention and indexed properties, AKS encryption at host	Security architect, data security officer	M2, before clusters and node pools are created	Customer key policy and data classification decide them; two cannot be changed after creation
OpenSearch provider (OD-03)	Enterprise architect	M2	Provider zone awareness, slow-log export and snapshot terms depend on it
DEV tests whose result no document settles: FS-12, FS-24, FS-33, FS-34, IT-06, DT-04, DT-06, DT-07	Pega LSA, search and identity teams	M2	Record the result; it becomes the expected behaviour
Measured inputs for the sizing calculator	Performance lead	M3	All example inputs are illustrative
The customer's Okta token endpoint rate limit	Identity team	M2	Enter in the calculator; compare with the measured token rate
AKS network policy engine and three-zone node pools (AS-08, AS-09)	Platform team	Before M2	Both are fixed when the cluster or pool is created
Permission to reuse third-party images	Customer legal	Before external sharing	Appendix G of the runbook

7 How to repeat the checks

1. From the `runbook` folder, generate the values files and render each with `helm template` against charts 4.13.0. Every render must complete without errors.
2. In the rendered output, check: SRS URL ends in `:8443`; no SRS NetworkPolicy from the chart; `topologySpreadConstraints` on both tiers; `JAVA_OPTS` present; SRS replicas 2 or 3.
3. Run `python3 build_doc.py` and `python3 qa_check.py`. The build must report no missing entries and no uncited references; the QA script must report no missing sections and no wording issues.
4. Open the sizing calculator, replace the example inputs with measured values, and compare the outputs with Section 16.8 of the runbook.
5. Before each rehearsal, recheck the vendor pages in the runbook's Section 3 and Appendix F.